Vulnerability Assessment Report

Future Interns Task 1 (2026)

Details

Name: Nhletelo Shibambu

Program: Future Interns Cyber Sec Program

Date: 20 April 2026

Tools: Nmap | OWASP ZAP | SecurityHeaders

EXECUTIVE SUMMARY

Executive Summary

This report presents the results of a vulnerability assessment conducted on a live website. The objective was to identify security weaknesses that may expose the system to cyber threats.

The assessment identified multiple vulnerabilities, including missing security headers and information exposure. These issues could lead to attacks such as data theft and website compromise.

Immediate remediation is recommended to improve security.

SCOPE

Scope of Assessment

Content:

- Target Website: https://juice-shop.herokuapp.com
- Type: Read-only testing
- No exploitation performed

Out of Scope:

- No brute force attacks
- No system disruption

TOOLS USED

Tools Used

Content:

- Nmap → Network scanning
- OWASP ZAP → Vulnerability detection
- Browser DevTools → Inspect frontend
- SecurityHeaders.com → Header analysis

SUMMARY OF FINDINGS

Key Findings

Vulnerability	Risk
Missing Security Headers	HIGH
Information Disclosure	MEDIUM
Open Ports	LOW
Server Error (503)	MEDIUM

HIGH RISK FINDING

Missing Security Headers

Risk Level: HIGH

Content:
The website received a grade **F** due to missing critical security headers.

Impact:

- Vulnerable to XSS attacks
- Clickjacking risk
- Data exposure

Fix:

- Implement Content Security Policy
- Enable HSTS
- Add X-Frame-Options

Missing Headers

Strict-Transport-Security	HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".
Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

MEDIUM RISK

Information Disclosure

Content:
The application exposes server details and error responses.

Impact:
Attackers can use this information to plan attacks.

Fix:

- Hide server information
- Disable detailed error messages

LOW RISK

Content:
Some ports are open and may not be required.

Impact:
Increases attack surface

Fix:

- Close unused ports
- Use firewall restrictions

ADDITIONAL ISSUE

Server Error (503)

Content:
The server returned a **503 Service Unavailable** response.

Impact:

- Service instability
- Security controls may fail

Fix:

- Improve server availability
- Monitor uptime

RECOMMENDATIONS

Recommendations

Content:

- **Implement missing security headers**
- **Regularly update software**
- **Perform security testing frequently**
- **Monitor server performance**

SLIDE 11 — EVIDENCE

Title: Supporting Evidence

Security Report Summary

F

Site:	https://juice-shop.herokuapp.com/
IP Address:	54.220.192.176
Report Time:	20 Apr 2026 12:12:34 UTC
Headers:	✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
Advanced:	Ouch, you should work on your security posture immediately: Start Now

Missing Headers

Strict-Transport-Security	HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".
Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

CONCLUSION

Conclusion

Content:
The assessment identified several vulnerabilities that could impact the security of the website. Addressing these issues will significantly improve the system's protection against cyber threats.